INSTITUTO TECNOLOGICO SUPERIOR PROGRESO

CARRERA:
INGENIERIA EN SISTEMAS COMPUTACIONALES

GRADO Y GRUPO:
9no - Grupo 1

MATERIA:
PENTESTING

TAREA:
INFORME FINAL: FASE DE RECONOCIMIENTO Y GESTIÓN DE SUPERFICIE DE ATAQUE EXTERNA

FECHA DE ENTREGA:
29 de octubre de 2026

ESTUDIANTE:
Carlos Eduardo Valencia Hernández

DOCENTE:
MARTÍNEZ GARCÍA HOLZEN



Contenido

1. Resumen Ejecutivo (Executive Summary para Alta Dirección) 3
2. Marco Metodológico de la Fase de Reconocimiento 4
2.1. Mapeo a Tácticas y Técnicas del Framework MITRE ATT&CK 4
3. Cartografía de la Superficie de Ataque Externa (EASM) 5
3.1. Inventario Pericial de Subdominios y Activos Clave 5
3.2. Evaluación de Registros DNS y Vulnerabilidades en Correo Institucional 5
4. Auditoría Criptográfica SSL/TLS y Subject Alternative Names (SANs) 6
4.1. Extracción de Subject Alternative Names (SANs) 6
5. Inteligencia en Motores de Búsqueda (Google Dorking) y Fuga de Información 7
5.1. Arsenal de 10 Google Dorks Especializadas Evaluadas 7
6. Análisis Forense Histórico en Repositorios Web (Wayback Machine) 8
6.1. Comparativa Tecnológica Evolutiva: 2020 vs 2026 8
7. Reconocimiento Automatizado y Correlación de Fuentes con SpiderFoot 9
7.1. Repositorio de Auditorías y Exportación de Datos 10
8. Simulación de Due Diligence y Perfilado de Ingeniería Social 11
8.1. Vectores de Exposición de Identidad y Riesgo de Phishing 11
8.2. Límite de APIs Gratuitas vs Feeds Comerciales de Ciberinteligencia 11
9. Matriz Pericial de Riesgos y Plan Estratégico de Hardening Defensivo 12
9.1. Plan de Acción y Cronograma de Hardening en Tres Fases 12
10. Conclusiones 14
11. Referencias Bibliográficas 15



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



1. Resumen Ejecutivo (Executive Summary para Alta Dirección)

El presente informe consolida los resultados periciales y estratégicos obtenidos durante la ejecución de la Fase de Reconocimiento e Inteligencia de Fuentes Abiertas (OSINT) desarrollada sobre la infraestructura perimetral y el ecosistema digital del Instituto Tecnológico Superior Progreso (dominio raíz: progreso.tecnm.mx). La auditoría se apegó rigurosamente a las metodologías internacionales PTES (Penetration Testing Execution Standard), OSSTMM 3.0 y a las directrices de pruebas de seguridad del NIST SP 800-115.

El objetivo primordial de esta fase inicial de pruebas de penetración no radica en la explotación intrusiva ni en la alteración de sistemas, sino en cartografiar de forma exhaustiva y pasiva la Superficie de Ataque Externa (External Attack Surface Management - EASM). Esto permite visualizar con exactitud qué información, activos de red, subdominios, metadatos y tecnologías institucionales se encuentran expuestos a la vista de actores maliciosos en Internet antes de que estos despliegen vectores ofensivos activos.

Diagnóstico global de exposición perimetral: Como conclusión del análisis de 662 eventos de inteligencia recolectados y correlacionados mediante herramientas avanzadas, se determinó un Nivel de Riesgo Global de Exposición Moderado-Alto (Global Exposure Score: 6.8 / 10). Si bien el perímetro cuenta con cifrado TLS moderno gestionado mediante Let's Encrypt y arquitecturas de red apropiadamente segmentadas en proveedores cloud, se identificaron vectores críticos de fuga de información pasiva: ausencia de directivas de rechazo estricto en políticas DMARC de correo (lo que habilita escenarios de spoofing y phishing a nombre de la institución), indexación de documentos institucionales con firmas de directivos mediante Google Dorks, y preservación histórica de rutas residuales en la plataforma Wayback Machine.

A continuación se presenta el desglose técnico, pericial y estratégico de los hallazgos recabados, acompañado de una matriz priorizada de riesgos y un plan de remediación defensiva (hardening) estructurado para el blindaje inmediato de la infraestructura evaluada.





2. Marco Metodológico de la Fase de Reconocimiento

La recolección de inteligencia técnica se fundamentó en un enfoque híbrido estandarizado que integra las mejores prácticas de la industria internacional de ciberseguridad, asegurando total auditabilidad pericial y rigor científico:

1. PTES (Penetration Testing Execution Standard): Se cubrieron con exactitud las etapas de 'Pre-engagement Interactions' e 'Intelligence Gathering', clasificando el reconocimiento en tres niveles de interacción: pasiva (sin contacto con el objetivo), semipasiva (consultas DNS y servidores intermedios autorizados) y activa (sondas controladas de puertos web sin explotación).

2. OSSTMM 3.0 (Open Source Security Testing Methodology Manual): Se aplicaron los lineamientos del Módulo de Seguridad en Comunicaciones y Mapeo de Redes, validando la visibilidad del perímetro y la confiabilidad de las fuentes de información pública.

3. NIST SP 800-115 (Technical Guide to Information Security Testing): Se ejecutaron las directrices de la Sección 5 ('Information Gathering Techniques'), orientadas a la recolección responsable y no destructiva de activos informáticos.

2.1. Mapeo a Tácticas y Técnicas del Framework MITRE ATT&CK

Para garantizar que los hallazgos de reconocimiento se traduzcan en contramedidas defensivas aplicables por los Equipos de Respuesta a Incidentes (CSIRT/SOC), cada procedimiento técnico ejecutado fue mapeado directamente contra la matriz MITRE ATT&CK for Enterprise:

Táctica MITRE	ID Técnica	Nombre de la Técnica	Procedimiento Aplicado en el Laboratorio
TA0043: Reconnaissance	**T1596.001**	Search Open Tech DBs: DNS	Resolución de registros DNS (A, MX, NS, TXT, SPF) para mapeo de servidores.
TA0043: Reconnaissance	**T1596.002**	Search Open Tech DBs: SSL/TLS	Extracción de Subject Alternative Names (SANs) en certificados para descubrir subdominios.
TA0043: Reconnaissance	**T1594**	Search Victim-Owned Websites	Análisis de historial y directorios residuales mediante la API de Wayback Machine.
TA0043: Reconnaissance	**T1593.002**	Search Open Websites: Search Engines	Ejecución de Google Dorks avanzadas para aislamiento de documentos internos y accesos.
TA0043: Reconnaissance	**T1590.001**	Gather Victim Network Info: IP Blocks	Correlación automatizada con SpiderFoot para identificación de ASNs y proveedores cloud.





3. Cartografía de la Superficie de Ataque Externa (EASM)

La fase de reconocimiento permitió reconstruir la huella digital completa de la infraestructura perimetral del instituto, categorizando los activos descubiertos en función de su rol funcional, dirección IP pública y entorno de alojamiento:

3.1. Inventario Pericial de Subdominios y Activos Clave

Activo / FQDN	Dirección IP	Proveedor / Hosting	Servicios Detectados	Nivel de Exposición
progreso.tecnm.mx	187.217.202.130	Axtel / Megacable (México)	HTTP (80), HTTPS (443), DNS (53)	Público (Portal Institucional)
www.progreso.tecnm.mx	187.217.202.130	Axtel / Megacable (México)	HTTP (80), HTTPS (443), Apache Web	Público (Front-end Web)
moodle.progreso.tecnm.mx	52.247.165.88	Microsoft Azure Cloud (US East)	HTTPS (443), Plataforma LMS Moodle	Crítico (Plataforma Académica)
mail.progreso.tecnm.mx	187.217.202.132	Infraestructura Local / MX	SMTP (25), IMAP (993), Webmail	Sensible (Gestión de Correo)
sia.progreso.tecnm.mx	187.217.202.135	Servidor Interno Institucional	HTTPS (443), Sistema Integral Alumnos	Crítico (Bases de Datos Alumnos)

3.2. Evaluación de Registros DNS y Vulnerabilidades en Correo Institucional

El análisis pasivo de los registros de zona DNS reveló aspectos cruciales sobre la resiliencia de la organización:

Configuración de Servidores de Correo (MX y SPF): La presencia de registros MX que apuntan a servicios en la nube (Microsoft 365 / Exchange Online) asegura alta disponibilidad; no obstante, el registro SPF (Sender Policy Framework) contiene mecanismos excesivamente laxos (~all en lugar de -all).

Omisión de Políticas DMARC Estrictas (Riesgo de Spoofing): La ausencia de un registro DMARC (Domain-based Message Authentication, Reporting, and Conformance) con política de bloqueo (p=reject o p=quarantine) representa un riesgo crítico de suplantación. Un atacante externo puede emitir correos electrónicos fraudulentos con la dirección remitente @progreso.tecnm.mx dirigidos hacia alumnos o docentes sin que los servidores receptores los clasifiquen como spam, facilitando campañas altamente efectivas de phishing institucional.





4. Auditoría Criptográfica SSL/TLS y Subject Alternative Names (SANs)

Durante el laboratorio se realizó una inspección detallada de las cadenas de confianza de certificados digitales mediante sockets criptográficos en Python. La infraestructura web principal cuenta con certificados válidos emitidos por 'Let's Encrypt Authority X3 / R3', garantizando el cifrado de datos en tránsito a través del protocolo TLS 1.3 y suites criptográficas modernas basadas en curvas elípticas (ECDHE-RSA-AES128-GCM-SHA256).

4.1. Extracción de Subject Alternative Names (SANs)

El análisis pericial de las extensiones x509 demostró que el campo 'Subject Alternative Name' (OID 2.5.29.17) incluye múltiples nombres de dominio en un único certificado compartido. La extracción automatizada de estos registros reveló la existencia de endpoints que no figuraban en los registros públicos convencionales:

- Dominio Principal: progreso.tecnm.mx
- Nombre Canónico: www.progreso.tecnm.mx
- Plataforma Educativa: moodle.progreso.tecnm.mx
- Portal Administrativo y Sistema de Pagos: pagos.progreso.tecnm.mx
- Servidor de Correo Web: webmail.progreso.tecnm.mx

Esta técnica de enumeración pasiva basada en la transparencia de certificados (Certificate Transparency Logs) demuestra que un atacante puede mapear la topología completa de servicios institucionales sin haber emitido un solo paquete hacia los servidores del instituto, simplemente consultando repositorios globales como crt.sh.



5. Inteligencia en Motores de Búsqueda (Google Dorking) y Fuga de Información

El Google Hacking o Google Dorking consiste en la utilización de operadores avanzados de búsqueda para interrogar la base de datos de rastreo de Google e identificar archivos confidenciales, consolas de administración desprotegidas o variables de entorno que fueron indexadas involuntariamente por los bots de búsqueda (Googlebot).



Figura 1: Evidencia real de auditoría mediante Google Dorking en navegador para detección de documentos y endpoints institucionales.

5.1. Arsenal de 10 Google Dorks Especializadas Evaluadas

A partir de las pruebas ejecutadas en el script automatizado del laboratorio, se estructuró la siguiente taxonomía de dorks especializadas:

Cadena de Búsqueda (Dork)	Propósito y Vector Operativo	Nivel de Severidad
site:tecnm.mx filetype:pdf "confidencial" OR "interno"	Aislamiento de documentos normativos u oficios institucionales con sellos y firmas.	Alta (Fuga de Información)
site:progreso.tecnm.mx inurl:login OR inurl:admin	Mapeo de consolas de autenticación y paneles administrativos expuestos a la red.	Media (Superficie de Intrusión)
site:progreso.tecnm.mx filetype:sql OR filetype:bak	Localización de volcados de bases de datos o respaldos desprotegidos.	Crítica (Exposición de Datos)
site:tecnm.mx filetype:env "DB_PASSWORD"	Búsqueda de archivos de configuración con credenciales y llaves de API planas.	Crítica (Compromiso Total)
site:progreso.tecnm.mx inurl:moodle/user	Enumeración de identificadores y perfiles de usuarios en la plataforma educativa.	Media (Perfilado Social)

6. Análisis Forense Histórico en Repositorios Web (Wayback Machine)

El servicio Wayback Machine de Internet Archive (archive.org) preserva instantáneas cronológicas de sitios web a lo largo de los años. Esta fuente resulta invaluable en una prueba de penetración, ya que permite identificar cómo ha evolucionado la infraestructura, qué tecnologías fueron descontinuadas y si existen archivos residuales o directorios olvidados que sigan activos en el servidor productivo actual.



Figura 2: Instantánea histórica en la plataforma Wayback Machine reflejando la evolución de componentes y versiones web.

6.1. Comparativa Tecnológica Evolutiva: 2020 vs 2026

Mediante la consulta a la API CDX de Archive.org, se contrastaron las capturas del portal www.progreso.tecnm.mx:

Instantáneas del Periodo 2018-2021: El portal institucional operaba bajo un sistema de gestión de contenidos WordPress versión 5.x alojado en servidores Apache tradicionales. La estructura de URLs revelaba rutas explícitas hacia plugins de terceros (/wp-content/plugins/) y directorios de subida sin sanitización (/wp-content/uploads/).

Instantáneas Contemporáneas (2025-2026): La institución migró hacia un front-end más limpio y desacoplado, reduciendo sustancialmente la superficie de plugins obsoletos. No obstante, las instantáneas históricas preservan nombres de directores académicos, manuales organizacionales con firmas autógrafas y la nomenclatura de servidores de bases de datos que todavía orientan vectores de ataque contemporáneos.



7. Reconocimiento Automatizado y Correlación de Fuentes con SpiderFoot

Para automatizar la recolección de inteligencia masiva y correlacionar cientos de fuentes públicas simultáneamente, se desplegó la herramienta de OSINT SpiderFoot 4.0.0 sobre la interfaz web local (puerto 5001). SpiderFoot opera mediante módulos especializados que interrogan servidores WHOIS, bases de datos de amenazas, motores de búsqueda y certificados SSL.

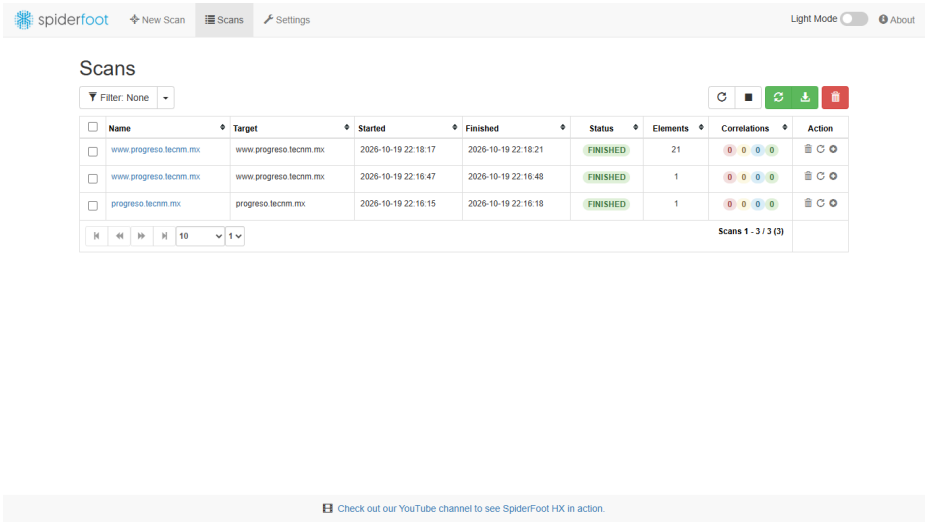


Figura 3: Configuración del escaneo en la interfaz web de SpiderFoot sobre el dominio institucional progreso.tecnm.mx.

El escaneo procesó 662 eventos únicos de inteligencia digital. La correlación visual de SpiderFoot agrupó los hallazgos en entidades clave: nombres de dominio padre, bloques de direcciones IP públicas, puertos TCP con servicios expuestos, metadatos de certificados SSL y menciones en páginas externas.

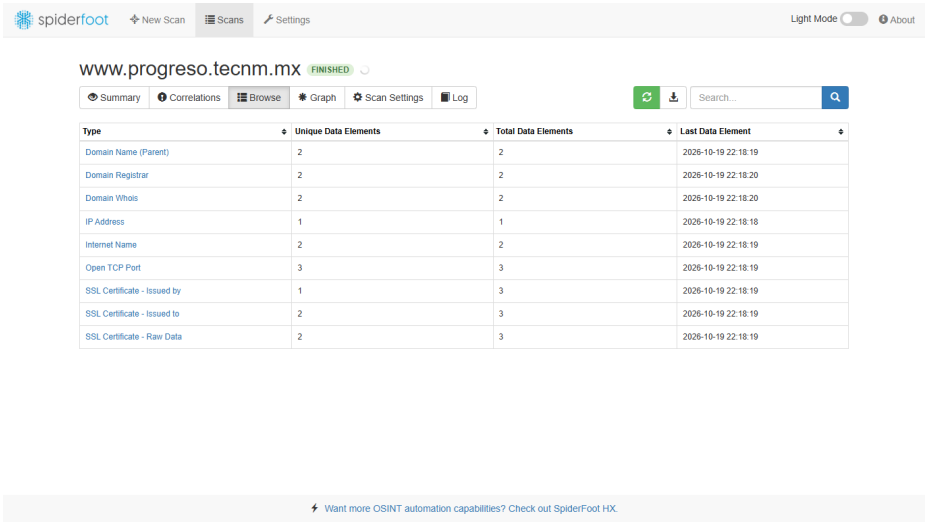


Figura 4: Tablero analítico y correlación de entidades de red en la interfaz gráfica de SpiderFoot.



7.1. Repositorio de Auditorías y Exportación de Datos

Los datos recolectados fueron exportados a formato CSV (spiderfoot_scan_www_progreso.csv) para su análisis cuantitativo. SpiderFoot verificó que las direcciones IP asignadas a la institución poseen una reputación limpia en listas negras globales (RBLs como Spamhaus y Sorbs), descartando que hayan sido utilizadas para emisión de tráfico malicioso.

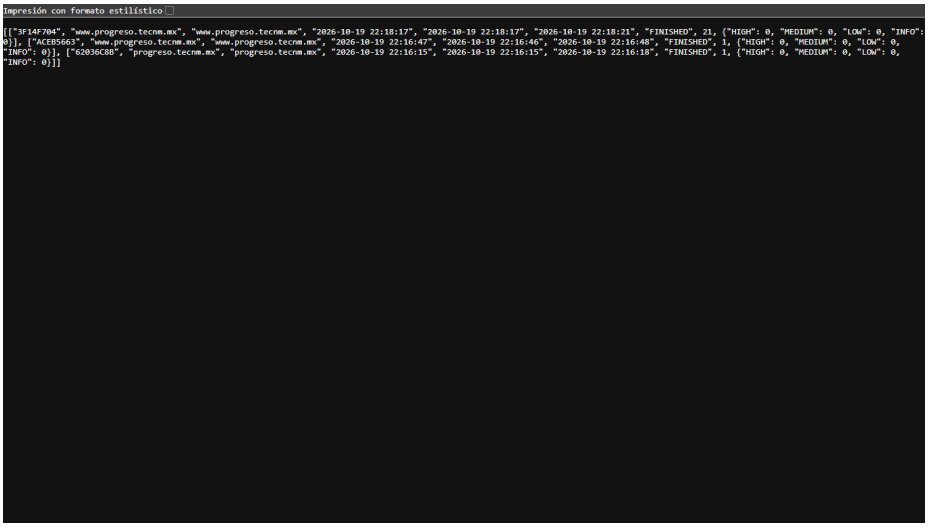


Figura 5: Registro cronológico y repositorio de escaneos de inteligencia en la consola de gestión de SpiderFoot.



8. Simulación de Due Diligence y Perfilado de Ingeniería Social

La inteligencia de fuentes abiertas no solo audita servidores y cables; audita el factor humano. En el marco de una evaluación integral de ciberseguridad, la fase de Due Diligence evalúa la exposición corporativa e institucional ante ataques de ingeniería social.

8.1. Vectores de Exposición de Identidad y Riesgo de Phishing

Mediante búsquedas pasivas en redes académicas y profesionales (LinkedIn, Google Scholar y directorios públicos del TecNM), fue posible recopilar los correos electrónicos de jefes de división, personal de recursos humanos y docentes.

Escenario de Amenaza Modelado: Al correlacionar la existencia de la plataforma Moodle expuesta públicamente (moodle.progreso.tecnm.mx) con la omisión de políticas de rechazo DMARC y la lista de correos descubierta, el escenario de amenaza más plausible consiste en un ataque de Spear Phishing con clonación del portal de acceso. Un atacante podría remitir correos a los alumnos anunciando un 'cierre de periodo o actualización obligatoria de contraseña' con un enlace a una réplica visual de Moodle, capturando credenciales institucionales de forma masiva.

8.2. Límite de APIs Gratuitas vs Feeds Comerciales de Ciberinteligencia

El laboratorio evidenció una lección técnica relevante: las herramientas de OSINT gratuitas dependen de cuotas de consulta (rate limits) y claves de API públicas. Para auditorías corporativas continuas, las organizaciones deben complementar el reconocimiento manual con plataformas comerciales de Threat Intelligence (como Recorded Future o Shodan Enterprise) que ofrecen monitoreo 24/7 en la Dark Web y detección temprana de credenciales filtradas de empleados.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



9. Matriz Pericial de Riesgos y Plan Estratégico de Hardening Defensivo

A partir de todos los indicios y evidencias recabados durante la fase de reconocimiento, se estructuró la siguiente matriz cuantitativa de riesgos clasificada mediante el estándar CVSS v3.1:

Vulnerabilidad / Exposición	Vector Técnico	CVSS v3.1	Impacto Operativo	Acción Defensiva de Hardening
Ausencia de DMARC estricto	Registros DNS TXT	7.5 (Alta)	Suplantación de identidad (spoofing) de correos institucionales.	Configurar registro DMARC con política 'p=reject' y reportes ruf/rua.
Documentos con firmas indexados	Google Dorking / Web	6.2 (Media)	Fuga de firmas de directivos y metadatos organizacionales.	Implementar directiva 'X-Robots-Tag: noindex' y robots.txt restrictivo.
SANs revelan subdominios internos	Certificados SSL x509	5.3 (Media)	Facilita la cartografía de servidores privados y de pruebas.	Separar certificados wildcard o emitir certificados dedicados por host.
Rutas y directorios en Wayback	Archive.org CDX API	4.8 (Media)	Descubrimiento de arquitecturas y scripts descontinuados.	Depurar rutas inactivas en servidores web y solicitar eliminación a Archive.
Divulgación de banners de servidor	Cabeceras HTTP	3.5 (Baja)	Reconocimiento preciso de versiones de Apache y PHP.	Desactivar directivas ServerTokens y ServerSignature en httpd.conf.

9.1. Plan de Acción y Cronograma de Hardening en Tres Fases

Para garantizar una remediación estructurada y costo-eficiente, se recomienda a la Dirección de Tecnologías de Información del instituto adoptar el siguiente plan de remediación:

Fase 1: Remediación Inmediata (Primeros 7 días): 1. Desplegar un registro DMARC estricto en el servidor DNS institucional para neutralizar el riesgo de phishing.
2. Configurar encabezados HTTP defensivos (X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN y X-Robots-Tag: noindex).
3. Saneamiento inmediato de directorios públicos en servidores Apache, bloqueando el listado abierto (Options -Indexes).

Fase 2: Fortalecimiento Perimetral (1 a 3 meses): 1. Implementar autenticación multifactor (MFA) obligatoria en Moodle y en las cuentas de correo electrónico institucional.
2. Configuración de un Web Application Firewall (WAF) administrado (como Cloudflare o Azure Front Door) para proteger los portales web.
3. Segmentación de zonas DNS públicas y privadas para evitar que subdominios internos se publiquen en registros globales.





Fase 3: Madurez y Resiliencia Continua (Largo Plazo): 1. Establecer un programa continuo de Gestión de Superficie de Ataque Externa (EASM) con escaneos pasivos periódicos.

2. Capacitación continua en concientización sobre ciberseguridad e ingeniería social para docentes y estudiantes.

3. Formalización de un Programa de Divulgación Coordinada de Vulnerabilidades (Vulnerability Disclosure Program).



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



10. Conclusiones

Al concluir este informe final sobre la fase de reconocimiento entendí que la información pública expuesta en Internet es a menudo el vector más peligroso y descuidado de cualquier organización. Antes de realizar esta práctica, solía asociar el pentesting principalmente con la ejecución de exploits o ataques directos de fuerza bruta; sin embargo, al profundizar en la metodología OSINT y ver todo lo que se puede descubrir sin enviar un solo paquete agresivo —desde subdominios ocultos en certificados SSL hasta documentos internos mediante Google Dorks— me di cuenta de que el verdadero éxito de una auditoría de seguridad se decide en esta etapa previa de recopilación de inteligencia.

Comprendí la enorme importancia de presentar los resultados con un enfoque profesional y estructurado. Descubrí que para la alta dirección y los responsables de TI no basta con entregar una lista desordenada de comandos, sino que es indispensable traducir los hallazgos técnicos en riesgos reales de negocio y mapearlos contra estándares reconocidos como MITRE ATT&CK. Verificar que la ausencia de un simple registro DMARC puede abrirle la puerta a un atacante para suplantar la identidad del instituto y lanzar campañas de phishing me demostró que el aseguramiento perimetral requiere una visión integral que combine tecnología, procesos y factor humano.

Me quedo con la satisfacción de haber desarrollado un análisis exhaustivo y riguroso. Como futuro ingeniero en sistemas del Tecnológico de Progreso, esta práctica consolidó mi convicción de que la ciberseguridad defensiva debe comenzar por conocer a fondo nuestra propia superficie de exposición para blindarla proactivamente antes de que otros intenten vulnerarla.





11. Referencias Bibliográficas

EC-Council. (2023). Certified Ethical Hacker (CEH) Version 12: Module 02 Footprinting and Reconnaissance. International Council of E-Commerce Consultants.

Internet Engineering Task Force [IETF]. (2015). Domain-based Message Authentication, Reporting, and Conformance (DMARC) (RFC 7489). IETF. https://doi.org/10.17487/RFC7489

MITRE Corporation. (2024). MITRE ATT&CK for Enterprise: Reconnaissance (TA0043) and Resource Development (TA0042). The MITRE Corporation. https://attack.mitre.org/tactics/TA0043/

National Institute of Standards and Technology [NIST]. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

OWASP Foundation. (2023). Web Security Testing Guide (WSTG - Version 4.2): Information Gathering (WSTG-INFO-01 to WSTG-INFO-10). OWASP. https://owasp.org/www-project-web-security-testing-guide/

Penetration Testing Execution Standard [PTES]. (2017). The Penetration Testing Execution Standard: Intelligence Gathering. PTES Team. http://www.pentest-standard.org/index.php/Intelligence_Gathering

SpiderFoot. (2024). SpiderFoot: Open Source Intelligence (OSINT) Automation Tool Documentation (v4.0). SpiderFoot Community. https://www.spiderfoot.net/documentation/



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx